

MICROSOFT IDENTITY PLATFORM CHECKLIST

Evidence-backed integration review and owner attestation

Control	Value
Application	CertScore.ai Microsoft MCP endpoint
Scope	Single-tenant Entra app-only client-credentials integration; AWS-hosted protected MCP API
Assessment date	2026-08-23
Source	Microsoft identity platform best practices and recommendations
Disposition	Technically reviewed; owner attestation required for live/account items

Questionnaire answer: Select “Yes” after the accountable owner signs this attestation and confirms the owner/action items below. Until then, keep “No.”

1. Review conclusion

The Microsoft checklist is integration guidance, not a full application audit. This review applies it only to the CertScore Microsoft MCP integration: a single-tenant, service-to-service client-credentials flow. Interactive user, mobile, delegated-consent, and Microsoft Graph-content recommendations are not applicable. The AWS API validates inbound tokens; it does not acquire tokens or call Microsoft Graph.

The technical evidence supports the scoped controls below. Repository artifacts cannot prove current account ownership, policy acceptance, or live Conditional Access testing, so those items are explicitly assigned to the accountable owner.

2. Line-by-line checklist review

Area	Checklist practice	Status	Evidence / action
Basics	Read and follow Microsoft platform policies.	Owner attestation	Confirm current platform-policy acceptance and retain the account record.
Ownership	Keep app-management account and registration ownership current.	Owner attestation	Verify live Entra/Partner Center owners; remove unnecessary owners.
Branding	Follow branding guidance; use meaningful name and logo.	Pass	Manifest contains representative CertScore.ai name, website, privacy/terms links, and icons.
Privacy	Provide terms and privacy statement links.	Pass	https://certscore.ai/terms and https://certscore.ai/privacy .
Security	Maintain owned, secure, non-wildcard redirect URIs.	N/A	App-only client credentials; no interactive redirect URI.
Security	Minimize and monitor app-registration owners.	Owner action	Verify the live Entra owner list.
Security	Do not enable implicit grant unless required.	Pass	Client-credentials flow; no implicit grant in documented setup.
Security	Do not use ROPC/password collection.	Pass	No end-user password handling; app-only token flow.
Security	Protect confidential credentials; prefer certs/managed identity; use Key Vault if secret is unavoidable.	Owner exception	Client secret is in Azure Key Vault for certification. Owner must approve the secret-vs-certificate decision and rotation evidence.
Security	Request least-privilege permissions.	Pass	Only the application role `Mcp.Access`; no Graph permissions.
Security	Define API permissions and check expected token permissions.	Pass	Validator checks tenant, issuer, audience, client, token version, and required role.
Implementation	Use modern OAuth 2.0/OpenID Connect.	Pass	Entra v2 OAuth 2.0 client credentials and JWT bearer tokens.
Implementation	Use MSAL when the app acquires tokens.	N/A for AWS API	AWS validates inbound tokens with `jose`; Microsoft certification/runtime owns token acquisition.
Implementation	Parse access tokens only as the protected web API.	Pass	AWS is the resource server and validates inbound tokens before dispatch.
Implementation	Migrate ADAL applications to MSAL.	N/A	No ADAL dependency or legacy ADAL flow.
Implementation	Configure mobile redirects and broker SSO.	N/A	No mobile client in scope.
Implementation	Use a secure token cache per account.	N/A	No interactive user token cache; flow is app-only.
Implementation	Use Graph where required data is available through Graph.	N/A	No Microsoft customer content is required; no Graph permissions.

Area	Checklist practice	Status	Evidence / action
End-user experience	Provide an understandable consent experience.	Scoped/N/A	No interactive user consent UX; admin consent is recorded for the application role.
End-user experience	Use silent auth before interactive login; avoid prompt=consent.	N/A	No interactive sign-in flow.
End-user experience	Use Graph for optional user-data enrichment.	N/A	No user-data enrichment.
End-user experience	Register required permissions and use incremental consent where applicable.	Scoped pass	One application role with administrator consent; delegated incremental consent is not applicable.
End-user experience	Implement clean single sign-out.	N/A	No interactive user session.
Testing	Test Conditional Access policies.	Owner action	Retain a live workload-identity policy test result before asserting full completion.
Testing	Test all supported account types.	Scoped pass	Single-tenant organizational account type only; consumer, child, mobile, and sovereign types are out of scope.

3. Evidence register

- /Users/benmasek/WC01/outputs/microsoft-mcp-certification-v2/microsoft_mcp_msft_endpoint_readiness.md
- /Users/benmasek/WC01/outputs/microsoft-mcp-certification-v2/azure_setup.md
- /Users/benmasek/WC01/apps/mcp/src/microsoft-entra-auth.ts
- /Users/benmasek/WC01/outputs/microsoft-mcp-certification-v2/package/manifest.json
- <https://learn.microsoft.com/en-us/entra/identity-platform/identity-platform-integration-checklist>

4. Owner attestation and closure

By signing below, the accountable owner confirms that live Entra/Partner Center owner records are current, Microsoft platform policies are understood and followed, the credential approach and rotation evidence are accepted, and Conditional Access testing has been completed or formally scoped as not applicable.

Attestation item	Record
Accountable owner	_____
Title / organization	_____
Approval date	_____
Credential decision / rotation evidence	_____
Conditional Access test evidence	_____
Next checklist review date	_____
Signature / approval	_____

After signed closure: the organization may answer “Yes” for this scoped Microsoft identity integration.